

Schlüsselaustausch mit Diffie-Hellmann

IT-SICHERHEIT / SEMESTER 3 UND 4



1

AGENDA

- 01 ASYMMETRISCHE VERCHLÜSSELUNG
- 02 DIFFIE HELLMANN
- 03 TRANSPORT LAYER SECURITY

2

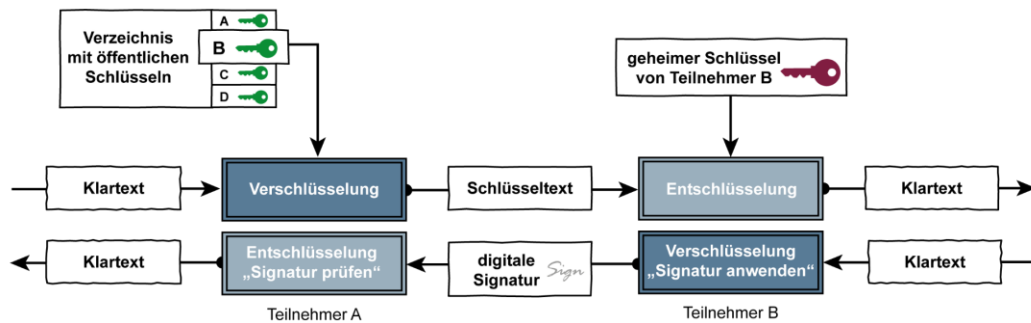
01

Asymmetrische Verschlüsselung

3

IT-SICHERHEIT / SEMESTER 3 und 4

Idee



4

Einführung

- Um das klassische Problem der Kryptographie, die Schlüsselverteilung zu erleichtern, wurden Verfahren entwickelt, die mit sogenannten „**öffentlichen Schlüsseln**“ oder **Public-Keys** arbeiten.
- Diese Verfahren werden vielfach auch als **asymmetrische Verfahren** bezeichnet.
- Man geht dabei von Verschlüsselungsverfahren aus, bei denen zur Entschlüsselung ein anderer Schlüssel als zur Verschlüsselung verwendet wird, wobei die **folgenden zusätzlichen Forderungen** erhoben werden:
 - Der Schlüssel zur Entschlüsselung ist nicht aus dem Schlüssel zur Verschlüsselung ableitbar.
 - Die Verschlüsselung kann nicht durch einen Angriff mit ausgewählten Klartext gebrochen werden.
- Wenn diese beiden Bedingungen erfüllt sind, gibt es keinen Grund mehr, den Schlüssel zur Verschlüsselung geheimzuhalten.

Einführung

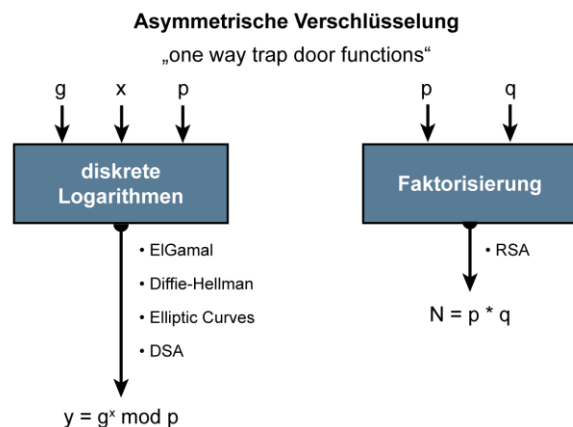
- Man kann sogar den für jeden Teilnehmer gültigen **Schlüssel veröffentlichen**.
- Daher nennen sich diese Verfahren **Public-Key-Verfahren**.
- Der **Schlüssel zur Verschlüsselung** wird als „**öffentlicher Schlüssel**“ bezeichnet und der **Schlüssel zur Entschlüsselung** „**privater**“ oder „**geheimer Schlüssel**“ genannt.
- Will A eine Nachricht an B senden, so entnimmt er den öffentlichen Schlüssel von B einem öffentlichen Verzeichnis, verschlüsselt die Nachricht damit und sendet sie an B.
- Da nur B den zugehörigen geheimen Schlüssel kennt, und da dieser Schlüssel weder aus dem öffentlichen Schlüssel noch aus der verschlüsselten Nachricht bestimmt werden kann, ist B tatsächlich der Einzige, der die Nachricht wieder entschlüsseln kann.
- Damit ist also eine sichere Kommunikation möglich, ohne dass dazu vorher eine geheime Schlüsselübermittlung zwischen A und B oder von dritter Seite an beide notwendig wäre.

Einführung

- Da vom Grundsatz her der geheime Schlüssel immer aus dem öffentlichen Schlüssel ableitbar ist, werden für Public-Key-Verfahren **Algorithmen gewählt, die auf der Lösung von Problemen der Komplexitätstheorie beruhen**.
- Derartige Funktionen werden auch mit „**one-way trap door**“-Funktionen bezeichnet.
- Bei „one-way“-Funktionen oder Einwegfunktionen handelt es sich um Funktionen, deren Funktionswert „**leicht**“ zu berechnen ist, während die Berechnung der inversen „**schwierig**“ oder sogar „**unmöglich**“ ist.
- Die Begriffe „leicht“, „schwierig“ und „unmöglich“ sollen den rechnerischen Aufwand beschreiben und hängen somit vom Entwicklungsstand der jeweiligen Computergeneration ab.
- Gibt es zu einer „one-way“-Funktion einen Parameter bzw. Schlüssel, mit dem die inverse Transformation „leicht“ zu berechnen ist, so spricht man von einer „one-way trap-door“-Funktion.

Einführung

- Ausgehend von dieser Überlegung, die Diffie und Hellman im Jahre 1976 veröffentlichten, wurden **verschiedene Vorschläge für Public-Key-Verfahren** gemacht.



Einfacher Vorgang vs. aufwändiger/schwieriger Vorgang

- Die asymmetrische Verschlüsselung basiert auf Aufgaben, die in eine Richtung einfach auszuführen sind, während man eine geheime Information braucht, um den Vorgang rückgängig zu machen.
- Verfügt jemand nicht über diese geheime Information, ist die Umkehrung des Vorgangs nicht in sinnvoller Zeit zu bewältigen.

einfacher Vorgang	aufwändiger/schwieriger Vorgang
offenes Bügelschloss schließen	Bügelschloss ohne Schlüssel öffnen
Farben mischen	Farben trennen

Ein mathematisches Problem dieser Art

- Auch in der Mathematik gibt es Operationen, die einfach und schnell auszuführen sind. Die Umkehrung jedoch ist selbst für einen Computer aufwändig und kann Jahre dauern.
- Ein Beispiel dafür ist das Multiplizieren zweier (Prim-)Zahlen. Jeder Computer kann pro Sekunde mehrere Milliarden Multiplikationen ausführen. Ein Produkt zweier Primzahlen in die beiden Faktoren zu zerlegen, ist jedoch ungleich aufwändiger – insbesondere wenn die Zahlen mehrere hundert Stellen lang sind.

1. Primzahl	2. Primzahl	Produkt der beiden Primzahlen
41	83	?
?	?	3397

Lösung:

- $41 \cdot 83 = 3403$. Berechnet nach den Regeln der schriftlichen Multiplikation.
- $3397 = 43 \cdot 79$. Durch Ausprobieren, also Division aller Primzahlen zwischen 0 und der Hälfte der Zahl.

02

Diffie-Hellman

11

IT-SICHERHEIT / SEMESTER 3 und 4

Diffie-Hellman-Schlüsselaustausch

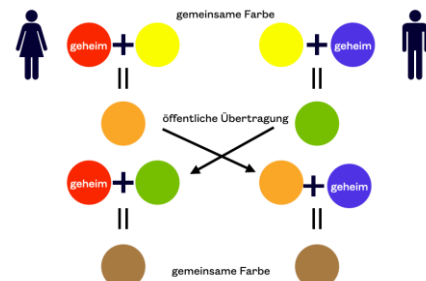
Das Diffie-Hellman-Protokoll ermöglicht,

- dass zwei Kommunikationspartner
- über eine öffentliche, abhörbare Leitung
- einen gemeinsamen geheimen Schlüssel in Form einer Zahl vereinbaren können, den nur diese kennen und ein potenzieller Lauscher nicht berechnen kann.

12

Analogie mit Farben

1. Alice und Bob wählen je eine **geheime** Farbe aus. Dass sie diese Farbe gewählt haben, teilen sie mit niemandem (Alice sagt es auch nicht Bob und umgekehrt!)
2. Weiter wählen sie jedoch noch zusätzlich eine **öffentliche** Farbe. Diese Farbe kennt jeder.
3. Alice und Bob mischen jeweils ihre zwei Farben (Alice rot und gelb, Bob gelb und blau) und schicken ihr Gemisch dem/der jeweilig anderen.
4. Wiederum mischen sie nun dieses erhaltene Gemisch mit ihren jeweilig geheimen Farben und kommen nun auf die gemeinsame Farbe braun.
5. Diese Farbe ist für niemanden anderen sichtbar/niemand kann aufgrund der Übertragung des grünen/orangen Farbgemisches auf die gemeinsame geheime Farbe braun kommen.



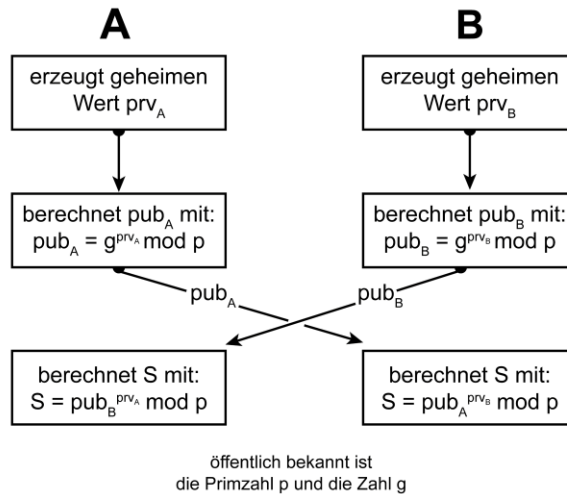
Diffie-Hellman: Fakten

- Erster Public Key Algorithmus in 1976
- Kein Verschlüsselungsalgorithmus
 - Gesicherter Austausch eines geheimen Schlüssels
 - keine Authentifizierung der Partner
- Das Schlüsselpaar von A besteht aus dem geheimen Schlüssel prv_A und dem öffentlichen Schlüssel pub_A

$$pub_A = g^{prv_A} \bmod n$$

- g und n sind öffentlich bekannt.
- n ist eine lange Primzahl und g eine zu n teilerfremde Zahl.

Diffie-Hellman: Verfahren



15

Modulo Berechnung

- Modulo-Rechnungen sind nichts anderes als Division mit Rest.
- Du kannst dir die Uhr als Analogie vorstellen. Die Uhr hat 12 Zahlen. Wenn ich jedoch über die 12 hinausgehe, z.B. auf 15 Uhr, dann ist das eigentlich dasselbe wie 3 Uhr Nachmittags.
- D.h. ich berechne: $15 : 12 = 1 \text{ Rest } 3$. Das kann man auch aufschreiben als: $15 \bmod 12 = 3$.

Weitere Beispiele:

- $7 \bmod 3 = 1$, weil $7 : 3 = 2 \text{ Rest } 1$.
- $8 \bmod 2 = 0$, weil $8 : 2 = 4 \text{ Rest } 0$.

16

Beim Diffie-Hellman-Schlüsselaustausch sind p und g öffentliche Startparameter, auf die sich alle Teilnehmer einigen.

p – die Primzahl (Modulus)

- p ist eine große Primzahl
- Alle Berechnungen finden modulo p statt
- Sie definiert die mathematische „Rechenwelt“, in der gearbeitet wird
- Sicherheit: p muss sehr groß sein (heute typischerweise mindestens 2048 Bit), sonst kann der geheime Schlüssel mit bekannten Angriffen berechnet werden.
- Kurz gesagt: p legt den Zahlenraum fest, in dem Diffie-Hellman operiert..

g – der Generator

- g ist eine Zahl kleiner als p
- Man nennt g einen Generator oder primitive Wurzel modulo p
- Mit g lassen sich durch Potenzen viele Werte modulo p erzeugen
- Bedeutung: Ein schlecht gewähltes g kann die Sicherheit deutlich schwächen
- In der Praxis werden standardisierte (p, g) -Paare verwendet
- Kurz gesagt: g ist der Startpunkt, von dem aus die geheimen Potenzen gebildet werden.

Beim Diffie-Hellman-Schlüsselaustausch sind p und g öffentliche Startparameter, auf die sich alle Teilnehmer einigen.

Ein Generator ist in der Mathematik eine Zahl (oder ein Element), mit der man durch wiederholte Anwendung einer Operation alle (oder fast alle) Elemente einer Struktur erzeugen kann.

Mit den Potenzen von g kann man alle möglichen Werte (außer 0) modulo p erzeugen.

Anschaulich erklärt Stell dir ein **Zifferblatt** vor:

- p bestimmt, wie viele Positionen es gibt
- g ist die **Schrittweite**

Wenn g ein Generator ist: springst du bei jedem Schritt weiter kommst irgendwann **an jeder Position genau einmal vorbei**

Wenn g kein Generator ist: landest du nur auf **einigen wenigen Positionen** der Rest bleibt unerreichbar → schlechte Sicherheit

Kleines Zahlenbeispiel

Nehmen wir: $p=7$ und $g = 3$ (Generator)

$$\begin{aligned} 3^1 \bmod 7 &= 3 \\ 3^2 \bmod 7 &= 2 \\ 3^3 \bmod 7 &= 6 \\ 3^4 \bmod 7 &= 4 \\ 3^5 \bmod 7 &= 5 \\ 3^6 \bmod 7 &= 1 \end{aligned}$$

Erzeugt: $\{1,2,3,4,5,6\}$ → Generator

$g = 2$ (kein Generator)

$$\begin{aligned} 2^1 \bmod 7 &= 2 \\ 2^2 \bmod 7 &= 4 \\ 2^3 \bmod 7 &= 1 \end{aligned}$$

Erzeugt nur: $\{1,2,4\}$ → kein Generator

Sicherheit beruht auf der Schwierigkeit des diskreten Logarithmusproblems

Gegeben sind drei Dinge:

- eine große Primzahl p
- ein Generator g
- ein Wert $y = g^x \bmod p$

➤ **Das diskrete Logarithmusproblem (DLP) ist:** Finde x , wenn g , p und y bekannt sind.

➤ Man schreibt: $x = \log_g(y) \bmod p$

Warum ist das schwierig?

- Vergleich mit „normalen“ Logarithmen
- Normaler Logarithmus: $10^x = 1000 \Rightarrow x = 3 \rightarrow$ leicht berechenbar

- Diskreter Logarithmus: $5^x \bmod 23 = 8 \Rightarrow x = ? \rightarrow$ kein effizienter Algorithmus bekannt

Das Problem:

- Modulo-Rechnung „verwischt“ die Information
- Potenzen wachsen sehr schnell
- Es gibt keine Abkürzung, nur extrem viele Versuche

Warum „schwierig“ = „sicher“? Rechnen vorwärts vs. Rückwärts

- Leicht: $g^a \bmod p$ berechnen
- Schwer: aus $g^a \bmod p$ das a finden
- Dieser Unterschied heißt **Einwegfunktion**: leicht in eine Richtung, praktisch unmöglich in die andere

Bedeutung von „praktisch unmöglich“

Wichtig: „Schwierig“ heißt nicht mathematisch unmöglich, sondern:

- benötigte Rechenzeit > Alter des Universums
- selbst mit allen heutigen Supercomputern

Beispiel:

- $p \approx 2048$ Bit
- Schlüsselraum $\approx 2^{2048}$
- Brute-Force: aussichtslos

$$5^x \bmod 23 = 8 \Rightarrow x = ?$$

Da die Zahlen klein sind, probieren wir die Potenzen.

$$5^1 \bmod 23 = 5$$

$$5^2 \bmod 23 = 2$$

$$5^3 \bmod 23 = 10$$

$$5^4 \bmod 23 = 4$$

$$5^5 \bmod 23 = 20$$

$$5^6 \bmod 23 = 8$$

$$5^6 \equiv 8 \pmod{23}$$

- zeigt gut, wie man einen diskreten Logarithmus findet
- und warum das bei großen Zahlen (wie in Diffie-Hellman) praktisch unmöglich wird.

Perfect Forward Secrecy: Definition

- **Perfect Forward Secrecy (PFS) ist eine kryptografische Cyber-Sicherheitseigenschaft**, die eine Aussage über die Abhängigkeit von verschiedenen Schlüsseln untereinander trifft.
- Sitzungsschlüssel werden nicht übertragen und sind nicht aus dem Masterschlüssel rekonstruierbar.
- Ein Masterschlüssel ist zum Beispiel der private Schlüssel eines Publik-Key-Verfahrens, der im Schlüsselaustauschprotokoll verwendet wurde.
- PFS bietet eine wesentlich höhere IT-Sicherheit vor nachträglicher Entschlüsselung.

Warum ist PFS wichtig?

- Bedrohung: Angreifer speichern verschlüsselte Daten („heute sammeln, morgen knacken“) und warten auf Schlüsselkompromittierung oder schwächere Algorithmen.
- Risiko ohne PFS: Bekanntwerden des Masterschlüssels → alle alten Sitzungen können entschlüsselt werden.
- Mit PFS: Jede Sitzung hat einen eigenen Schlüssel, der nach Ende gelöscht wird → keine Rückschlüsse möglich.

Perfect Forward Secrecy: Umsetzung und Eigenschaften

- Diffie-Hellman-Verfahren (Shared Secret), kein Austausch des Sitzungsschlüssels.
- Eigenschaften:
 - Schlüssel nur für eine Session gültig.
 - Bei jeder neuen Verbindung wird ein neuer Schlüssel berechnet.
- Einsatz: Standard bei TLS 1.3, auch bei SSL und IPSec.
- Nachteil: Höherer Rechenaufwand.



03

Transport Layer Security

23

IT-SICHERHEIT / SEMESTER 3 und 4

Idee von TLS/SSL

- Da das Internet offen ist und die Angriffsmöglichkeiten sowie Angriffswahrscheinlichkeiten sehr groß sind, ist die **Nutzung einer verschlüsselten und integritätsgesicherten Kommunikation zwischen Client und Server** von besonderer Bedeutung.
- Sehr viele Cyber-Sicherheitsaspekte im Web, wie Eingabe von Passwörtern und Kreditkarten-Informationen haben mit der Einrichtung einer **vertrauenswürdigen Verbindung zwischen Client und Server** zu tun.
- Der vorherrschende Ansatz für die Transportverschlüsselung ist die Verwendung von **TLS (Transport Layer Security) / SSL (Secure Socket Layer) – TLS/SSL**.
- TLS/SSL ist ein anwendungsunabhängiges Cyber-Sicherheitsprotokoll, das logisch auf einem Transportprotokoll aufsetzt.

24

Cyber-Sicherheitsfunktionen von TLS/SSL

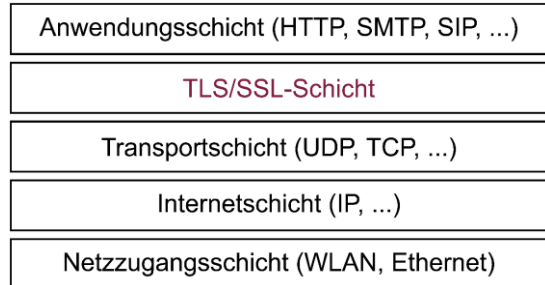
- **Authentifikation von Server und Client** unter Verwendung von asymmetrischen Verschlüsselungsverfahren und elektronischen Zertifikaten.
- **Vertrauliche Client-to-Server (Ende-zu-Ende)Datenübertragung** mit Hilfe symmetrischer Verschlüsselungsverfahren unter der Nutzung eines gemeinsamen Sitzungsschlüssels.
- **Sicherstellung der Integrität und Authentizität** der transportierten Daten unter Verwendung des HMAC-Verfahrens.
- TLS/SSL bietet auch die **Komprimierung** der Daten an.

Geschichte

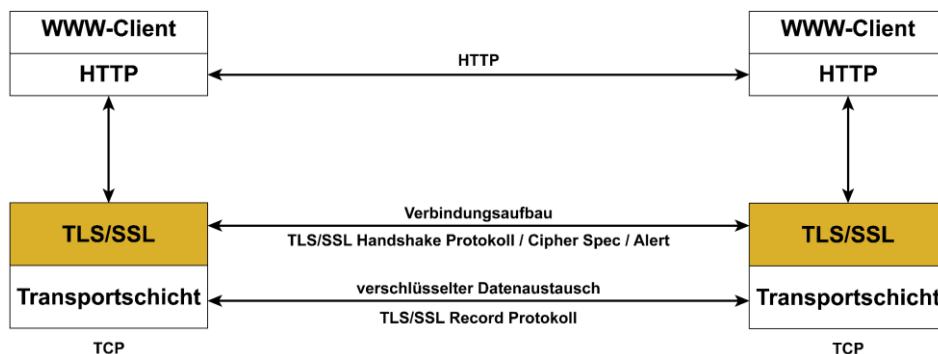
- Die Idee kam von Netscape, die die **erste Version von SSL 1994** veröffentlichte.
- 1999 wurde SSL von der **IETF als Standard festgelegt** und umbenannt zu Transport Layer Security (TLS).
- Da aber heute noch im Sprachgebrauch SSL fest verankert ist, wird im Weiteren immer von TLS/SSL gesprochen.
- Praktische Relevanz von TLS/SSL
 - Da TLS/SSL **in allen wichtigen Internet-Technologien wie Browsern, Web-Servern, E-Mail-Servern** usw. eingebunden ist, wird TLS/SSL faktisch als Standard für die Transportverschlüsselung verwendet.

Kommunikationsarchitektur

- TLS/SSL kann eine **Vielzahl höherer Anwendungsprotokolle unterstützen**, wie HTTP, SMTP, SIP, IMAP, FTP, Telnet.
- Die genauen **Sicherheitseigenschaften des TLS/SSL-Kanals werden bei der Einrichtung der verschlüsselten und integritätsgesicherten Kommunikation zwischen Client und Server festgelegt**.
- Sicherheitseigenschaften sind: **Authentifikation** von Client und Server sowie **Integrität, Authentizität** und **Vertraulichkeit** der Transportdaten.

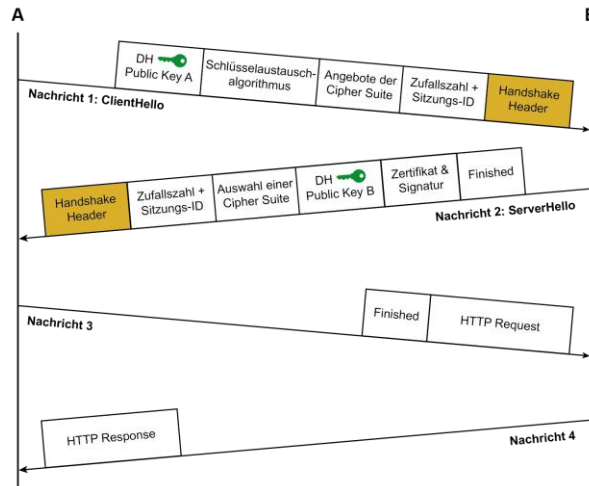


Verbindungsaufbau



IT-SICHERHEIT / SEMESTER 3 und 4

Der Handshake zum Verbindungsaufbau



[Quelle: Cyber Sicherheit; Pohlmann, Norbert; Springer Fachmedien Wiesbaden; 2. Auflage 2022, Kapitel 11 Transport Layer Security]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

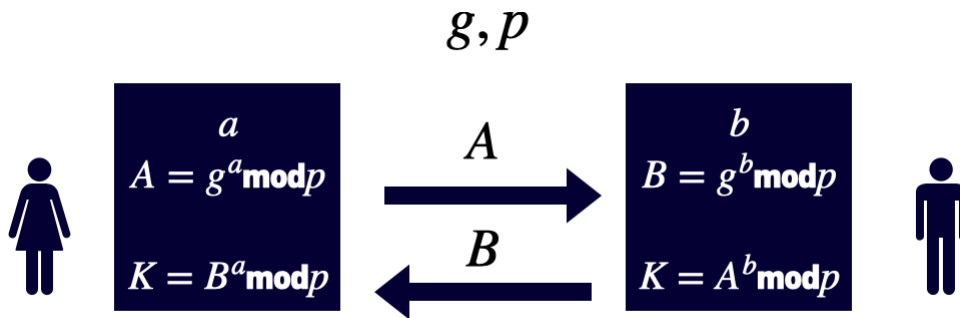
29

29

BACKUP

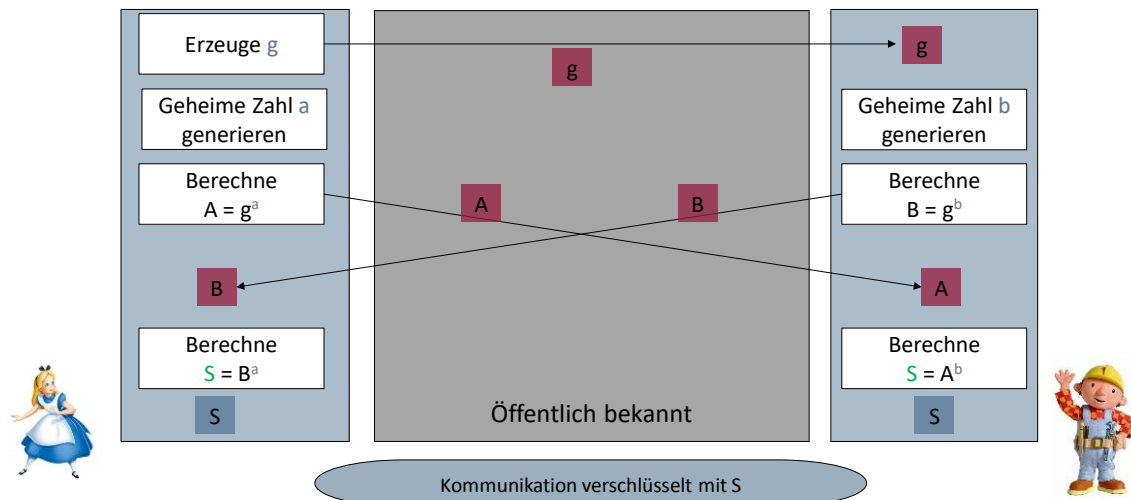
30

Diffie-Hellman-Protokoll



31

Diffie-Hellman: Verfahren



32

Kryptographie – PDF Vorlesung

<https://norbert-pohlmann.com/wp-content/uploads/2022/02/2-kryptographie-vorlesung-prof-norbert-pohlmann-02-22.pdf>

Kryptographie – PDF Vorlesung

Kryptographie – PDF Vorlesung

In der Vorlesungen „Kryptographie“ werden Wissen über den Aufbau, die Prinzipien, die Architektur und die Funktionsweise von grundlegenden kryptographischen Verfahren behandelt. Kryptographische Verfahren spielen eine besondere Rolle bei vielen wichtigen Cyber-Sicherheitssystemen zur Gewährleistung der Cyber-Sicherheitsbedürfnisse, wie Vertraulichkeit, Authentifikation, Authentizität, Integrität und Verbindlichkeit. Themen sind: die wichtigsten Begriffe, elementare Verschlüsselungsverfahren, symmetrische Verschlüsselungsverfahren, Mode of Operation, asymmetrische Verschlüsselungsverfahren, One-Way-Hashfunktionen, hybride Verschlüsselungsverfahren und Quantensichere Algorithmen / Post-Quanten-Kryptographie. Dies ist eine Vorlesung aus dem Lehrbuch „Cyber-Sicherheit“.



 **KOSTENLOS DOWNLOADEN**

Übungen zur Cyber-Sicherheitsvorlesung „Kryptographie“ finden Sie hier:

 **ZUR ÜBUNG**

Glossar „Cyber Sicherheit“

<https://norbert-pohlmann.com/category/glossar-cyber-sicherheit/>

Glossar „Cyber-Sicherheit“

Im Glossar „Cyber-Sicherheit“ werden einige Begrifflichkeiten erklärt, um das Verständnis für die Cyber-Sicherheit zu verbessern.



Buch: „Cyber-Sicherheit“

Logo Cyber-Sicherheit Glossar



Gerne können Sie von Ihrer Webseite auf das Glossar Cyber-Sicherheit verlinken und hierzu auch das Logo verwenden. Zusätzlich bieten wir Ihnen ein **iframe** an, das das gesamte Glossar enthält.
[Tools zur Verlinkung](#)